

Executive Cybersecurity Risk Assessment

Mido Technologies | GRC Portfolio Extension

Executive Summary

Mido Technologies is a fictional small business used in a WGU cybersecurity capstone. The original assessment identified material weaknesses across wireless security, network architecture, identity and access management, patching, endpoint protection, backup and recovery, email security, and employee security awareness. The project then designed and simulated remediation measures intended to reduce the organization's exposure while remaining practical for a small-business environment.

Overall assessment: The initial environment presented a high level of cybersecurity risk because several weaknesses could combine to enable unauthorized access, lateral movement, credential compromise, phishing, data loss, or delayed threat detection. The capstone's layered remediation substantially improved the simulated security posture, although email-authentication validation remained incomplete.

Highest-Priority Risk Areas

Risk Area	Business Exposure	Recommended / Implemented Response
Wireless security	Legacy WEP could expose network traffic and permit unauthorized access.	Replace WEP with WPA3 and document secure wireless configuration.
Network segmentation	A flat network increases the potential for lateral movement from guest or IoT devices.	Separate employee, guest, and IoT traffic using VLANs and access-control rules.
Identity and access	Shared credentials and weak authentication reduce accountability and increase credential risk.	Use individual accounts, stronger password controls, MFA for privileged access, and compensating controls for legacy systems.
Patch / endpoint security	Unpatched systems and limited monitoring increase exploitability and reduce detection capability.	Establish scheduled patching, endpoint protection, host firewalls, centralized logging, and detection workflows.
Business continuity	Lack of formal backups could increase operational impact from ransomware or system failure.	Use cloud plus encrypted offline backups, versioning, access controls, and recovery testing.
Email / human risk	Weak email authentication and untrained personnel increase phishing and spoofing exposure.	Configure SPF/DKIM/DMARC and provide role-based security-awareness training and assessments.

Risk Treatment and Residual Exposure

The portfolio risk register assigns likelihood and impact scores to structure the capstone findings. Those numeric scores are portfolio judgments and were not explicit numeric ratings in the original WGU report. The treatment strategy is primarily mitigation: reduce risk through stronger technical, administrative, and user-focused controls. Residual exposure remains where controls depend on ongoing maintenance, user behavior, legacy-system constraints, or incomplete validation.

Management Priorities

- 1. Sustain identity and access controls.** Maintain individual accounts, privileged-access MFA, account lifecycle procedures, and periodic access reviews. Where legacy applications cannot support MFA, retain compensating controls such as network restrictions and enhanced logging.
- 2. Maintain vulnerability and monitoring processes.** Treat patching, endpoint protection, logging, and alert review as recurring operational processes rather than one-time implementation activities.
- 3. Test business continuity.** Continue backup protection and periodically validate recovery so the organization can demonstrate that critical data can be restored after ransomware or system failure.
- 4. Complete email-security validation.** The capstone states that SPF, DKIM, and DMARC were not fully validated because of time and lab constraints. This should remain an open remediation item until configuration and testing are complete.
- 5. Continue workforce awareness.** Repeat phishing and security-awareness activities and use assessments to identify where additional training is needed.

Framework Alignment

As a portfolio extension, the identified risks and remediations are mapped to NIST Cybersecurity Framework (CSF) 2.0 categories. Examples include Identity Management, Authentication, and Access Control (PR.AA), Awareness and Training (PR.AT), Platform Security (PR.PS), Technology Infrastructure Resilience (PR.IR), Data Security (PR.DS), and Continuous Monitoring (DE.CM). This formal CSF 2.0 mapping was created after the original capstone; the capstone itself used NIST guidance and described mapping risks to security controls.

Conclusion

The assessment demonstrates a risk-based approach to improving a small-business cybersecurity program: identify material weaknesses, evaluate business impact, prioritize remediation, implement layered controls, validate outcomes, and document remaining limitations. The strongest management focus going forward should be sustaining the implemented controls and closing partially validated items rather than treating remediation as a completed one-time project.

Portfolio disclosure: This document is a GRC-focused executive summary created from an academic WGU capstone involving a fictional organization and simulated environment. It is not a report from professional employment or a real client engagement.